

Secure FHIR Transactions Based on the SMART on FHIR Approach in a Health Data Exchange

Rukshan RANATUNGE ^{a,1}, Palitha KARUNAPEMA ^a

^aMinistry of Health Sri Lanka

ORCID ID: Rukshan Ranatunge <https://orcid.org/0000-0002-5465-5796>, Palitha Karunapema <https://orcid.org/0000-0002-6553-2353>

Abstract. Health data is highly sensitive, and one of the most targeted segments of data in recent cyber-attacks. In the development of the National Electronic Health Record (NEHR), the health data exchanged in FHIR format between electronic medical records and the NEHR had to be secured. A SMART on FHIR standard based authentication tool was developed and implemented in the Ministry of Health data centre in Sri Lanka. The developed solution was released as an open-source tool that can be implemented to secure FHIR based data exchange. The complexity of the SMART on FHIR standard, and the lack of financial and technical capacity poses a long-term challenge to maintain a novel tool for implementation of the standard based authentication to protect FHIR data exchange.

Keywords. FHIR, Interoperability, Data, Security, Standards, Data Exchange, Electronic Medical Records

1. Introduction

There has been an increase in electronic medical records, medical devices, and clinical decision support systems globally, and there is a need for interoperability between the systems for better healthcare. However, along with this rapid growth and the sensitive nature of the data that is exchanged, health data has garnered growing attraction amongst cyber criminals and cyber threats [1]. Fast Health Interoperability Resources (FHIR) is currently the globally accepted syntactic interoperability standard allowing cross-country and system-wide health data exchange [2]. Due to the extreme sensitivity, it is important to secure the information exchange to secure the data exchange from cyber-attacks.

Sustainable Medical Application and Reusable Technologies (SMART) on FHIR is an interoperability standard based on FHIR that creates a secure and standardized framework for accessing and using healthcare data. Even though commercial and open-source solutions exist, they are not designed using the standard specification based on SMART on FHIR implementation guide [3]. The National Electronic Health Record (NEHR) which is a longitudinal health record of the citizens of Sri Lanka, needs to have a secure FHIR data exchange. The objective of this study is to develop and test the SMART on FHIR authentication mechanism, an OAuth2-based authentication and

¹ Corresponding Author: Rukshan Ranatunge, academia@ruky.me.

authorization server developed based on the SMART on FHIR standard and pilot the solution at the Ministry of Health Sri Lanka (MoH) alongside the NEHR implementation.

2. Methods

Initially a thorough requirement analysis was carried out to identify requirements within the NEHR to secure data exchange between the EMR and client software. This included an assessment of the NEHR architecture, national FHIR implementation guide, and interoperability layer of electronic health exchange. This allowed the identification of functional and non-functional requirements to cater to current and future needs of health data exchange.

Multi-stakeholder semi-structured interviews were conducted within the MoH which included information technology staff, health informaticians and administrations to find more specific implementation requirements within the MoH.

The SMART on FHIR implementation guide for authentication and authorization was analysed to understand OAuth2-based authentication workflow, and specifications outlined such as the cryptarithmic algorithms to develop an authentication tool based on the SMART on FHIR.

A literature review was carried out on published and grey literature to identify similar solutions or tools developed and implemented to secure health data in a FHIR based health information exchange in other countries. The Sri Lankan digital health blueprint was also included in the literature review to align FHIR Auth with the national digital health strategy.

Agile software development methodology was applied to develop the software with multiple iterations and feedback from the NEHR implementation team and selected EMR developers. Usability and stress testing was conducted using a simulated EMR system that exchanged synthetic FHIR resources with the FHIR server after development. The system was then deployed and piloted at the Ministry of Health data center.

3. Results

The requirement analysis identified that access to FHIR resources can be complex, with client software only requiring read access in some resources, while requiring both read and write access in other FHIR resources. The spread of data between multiple FHIR resources also added challenges and complexity to data security with granular resource-based access. For example, in a patient encounter for a laboratory test, patient information is stored as a '*Patient*' FHIR resource, while lab records are stored in '*DiagnosticReport*' FHIR resource. Therefore, there should be a separation of resource-based access depending on the requesting client software, i.e., a laboratory system should be able to modify the lab report (*DiagnosticReport*) but not the patient information (*Patient*), while the inverse is true for a personal medical record software used by a patient.

Following the interview of fourteen stakeholders it was evident that all requests to the FHIR server from EMRs and client software should be authorized and authenticated, with the maintenance of an audit trail. While the MoH data centre has the hardware capacity to pilot the FHIR authenticator tool.

The literature review identified the requirement of national health information exchange to have a secure data exchange in sharing health data. However, it did not yield similar solutions or implementations globally that are fully based on the SMART on FHIR authentication flow for server-side applications but identified mature implementations of SMART on FHIR authentication for client-side applications [4,5]. The literature search identified multiple solutions used in different open-source solutions implemented to secure health data but was not fully SMART on FHIR compliant.

After requirement collection, and literature reviews SMART on FHIR-compliant backend authentication and authorization tool FHIR Auth was developed. Following the OAuth mechanism the EMR/client software first registers on FHIR Auth. Following the OAuth EMR software can obtain a cryptographically signed token which is valid for 15 minutes according to the SMART on FHIR specification [6]. The client software can then use this token to access the FHIR server and the FHIR resources and the clinical information within them (**Figure 1**).

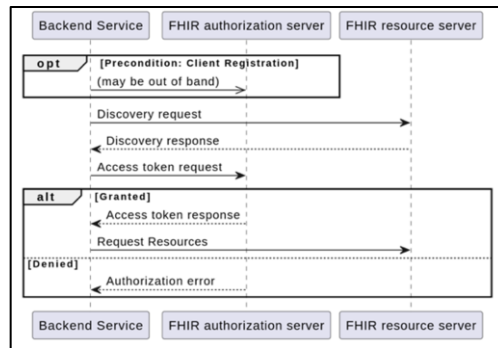


Figure 1. OAuth2 based SMART on FHIR Authentication flow.

FHIR Auth also has the ability to map to many different FHIR servers, by acting as a reverse proxy [7], while only exposing one public endpoint for EMR and client software to connect allowing one-to-many mapping of FHIR servers (**Figure 2**).

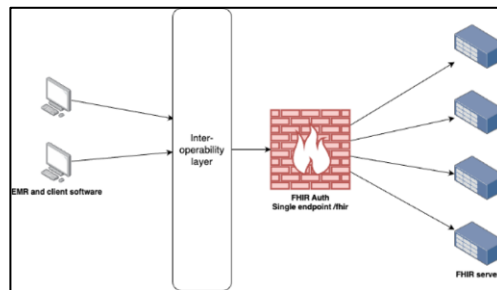


Figure 2. FHIR Auth based data exchange and reverse proxy.

FHIR Auth after development was implemented at the MoH data centre where it was piloted together with a FHIR server within the MoH (**Figure 3**). Initial testing showed that FHIR was fully compliant with the SMART on FHIR authentication flow. Stress testing and security testing carried out showed FHIR Auth is capable of

functioning at a national scale at the MoH data centre as an authorization and authentication server based on the SMART on FHIR standard. Automated testing was carried out based on multiple user roles performing different create, read, update, and delete actions on the FHIR server, coupled together with different FHIR resources.

FHIR Auth was developed in a modular manner, with a front-end, backend and database. The three modules were containerized for maintenance and separation of concern using Docker [8].

Figure 3. Client / EMR software registration page.

4. Discussion

The development of the FHIR Auth demonstrated that a fully functional authentication and authorization server can be developed by following the SMART on FHIR implementation guide. And that it can be implemented in parallel to a FHIR server, and health data exchange at the MoH NEHR can be secured with FHIR Auth. The open-source nature of FHIR Auth and the development of the FHIR Auth aligns with the national digital health blueprint and the OpenHIE architecture, allowing it to be re-used in any organizational and country setting [9,10].

The mixed resource-based, role-based access control proved to be successful in controlling access to data, and can be an alternative to currently used role-based and attribute-based access control methods and should be studied further [11].

The lack of documented implementation in the public and complexity of the implementation guide pose a challenge for the EMR providers to develop and include FHIR Authentication into their existing software and applications. This also highlights the requirement for capacity building within the MoH and EMR developers in the changing FHIR technology landscape.

It has been identified that health systems developed as innovations require an ownership of the tools functionality, and financial sustainability for long term adaptation [12]. This poses a challenge to the long-term sustainability of FHIR Auth as a novel innovative project because the MoH does not receive funding for the development and maintenance of FHIR Auth.

5. Conclusion

FHIR data exchange can be secured by using FHIR Auth and follows the standard outlined by SMART on FHIR implementation guide. The tool can be used at the national level to secure FHIR data exchange between health systems. Accommodation of the standard should also be carried out at the EMR level with the support of EMR vendors. However, the standard is challenging to fully implement in a resource-constrained setting due to technical complexity, and funding.

References

- [1] T. Lancet, Cyberattacks on health care—a growing threat, *The Lancet*. **403** (2024) 2263. doi:10.1016/S0140-6736(24)01074-2.
- [2] The International Patient Summary – key health data, worldwide, (2024). <https://international-patient-summary.net/> (accessed November 30, 2024).
- [3] Overview - SMART App Launch v2.2.0, (n.d.). <https://build.fhir.org/ig/HL7/smart-app-launch/index.html> (accessed November 30, 2024).
- [4] R.A. Bloomfield, F. Polo-Wood, J.C. Mandel, and K.D. Mandl, Opening the Duke electronic health record to apps: Implementing SMART on FHIR, *Int. J. Med. Inf.* **99** (2017) 1–10. doi:10.1016/j.ijmedinf.2016.12.005.
- [5] K.B. Waghlikar, J.C. Mandel, J.G. Klann, N. Wattanasin, M. Mendis, C.G. Chute, K.D. Mandl, and S.N. Murphy, SMART-on-FHIR implemented over i2b2, *J. Am. Med. Inform. Assoc.* **24** (2017) 398–402. doi:10.1093/jamia/ocw079.
- [6] Public-key cryptography, *Wikipedia*. (2024). https://en.wikipedia.org/w/index.php?title=Public-key_cryptography&oldid=1260272086 (accessed December 1, 2024).
- [7] Reverse proxy, *Wikipedia*. (2024). https://en.wikipedia.org/w/index.php?title=Reverse_proxy&oldid=1259950302 (accessed December 1, 2024).
- [8] Containerization (computing), *Wikipedia*. (2024). [https://en.wikipedia.org/w/index.php?title=Containerization_\(computing\)&oldid=1255148291](https://en.wikipedia.org/w/index.php?title=Containerization_(computing)&oldid=1255148291) (accessed December 1, 2024).
- [9] zemantic/fhir-auth: A Robust Authentication and Authorization Server for FHIR Servers 🔥, (n.d.). <https://github.com/zemantic/fhir-auth> (accessed December 1, 2024).
- [10] Architecture | OpenHIE Architecture Specification, (2022). <https://guides.ohie.org/arch-spec/architecture-specification/overview-of-the-architecture> (accessed December 4, 2024).
- [11] S. Mukherjee, I. Ray, I. Ray, H. Shirazi, T. Ong, and M.G. Kahn, Attribute Based Access Control for Healthcare Resources, in: Proc. 2nd ACM Workshop Attrib.-Based Access Control, Association for Computing Machinery, New York, NY, USA, 2017: pp. 29–40. doi:10.1145/3041048.3041055.
- [12] J.S. Marwaha, A.B. Landman, G.A. Brat, T. Dunn, and W.J. Gordon, Deploying digital health tools within large, complex health systems: key considerations for adoption and implementation, *Npj Digit. Med.* **5** (2022) 1–7. doi:10.1038/s41746-022-00557-1.